

Guía Técnica: Integración del Embedded SDK de Apache Superset en Aplicaciones Web PHP

Autor:

Wilson Iraldo Achagua Rodriguez

Institución:

Bitpointer S.A.S

Instructor:

Ing. Juan Fajardo Barrero

Fecha:

16 de junio de 2026

1 Introducción

El presente documento establece la guía técnica y el procedimiento estandarizado para incrustar *dashboards* analíticos de Apache Superset dentro de una aplicación web externa desarrollada en PHP. El propósito de este manual es documentar la arquitectura de integración, las configuraciones de seguridad requeridas en el servidor de Superset, y la lógica de programación necesaria para consumir la API y renderizar los gráficos dinámicamente mediante el *Embedded SDK*, sirviendo como base para futuras implementaciones.

2 Configuración del Servidor de Apache Superset

Por defecto, Superset bloquea la incrustación de sus gráficos en dominios externos. Para habilitar esta funcionalidad, es obligatorio modificar el archivo de configuración principal (`superset_config.py`), generalmente inyectado en el contenedor de Docker.

2.1 Habilitación de Características y CORS

Se debe habilitar la variable de entorno para tableros incrustados y relajar temporalmente las políticas de origen cruzado (CORS) para permitir la comunicación con el servidor web externo.

```
FEATURE_FLAGS = { "EMBEDDED_SUPERSET": True }
ENABLE_CORS = True
CORS_OPTIONS = {
    'supports_credentials': True,
    'allow_headers': ['*'],
    'resources': ['*'],
    'origins': ['*'] # Se debe modificar en producción
}
```

Listing 1: Configuración base en `superset_config.py`

2.2 Validaciones de Seguridad: CSRF y Roles de Invitado

Cuando la petición de autenticación proviene de un servidor (PHP) y no de un navegador, la validación CSRF (*Cross-Site Request Forgery*) interrumpe la conexión. Adicionalmente, Superset requiere que se defina explícitamente qué permisos hereda un usuario externo (Guest).

```
WTF_CSRF_ENABLED = False
GUEST_ROLE_NAME = "Public"
PUBLIC_ROLE_LIKE = "Gamma"
```

Listing 2: Ajustes de seguridad para la API y usuarios Guest

Al aplicar estos cambios, el rol *Public* heredará la capacidad de lectura. Posteriormente, en la interfaz visual de Superset, el administrador debe editar el rol *Public* y asignarle explícitamente el permiso `database access` sobre el conjunto de datos deseado.

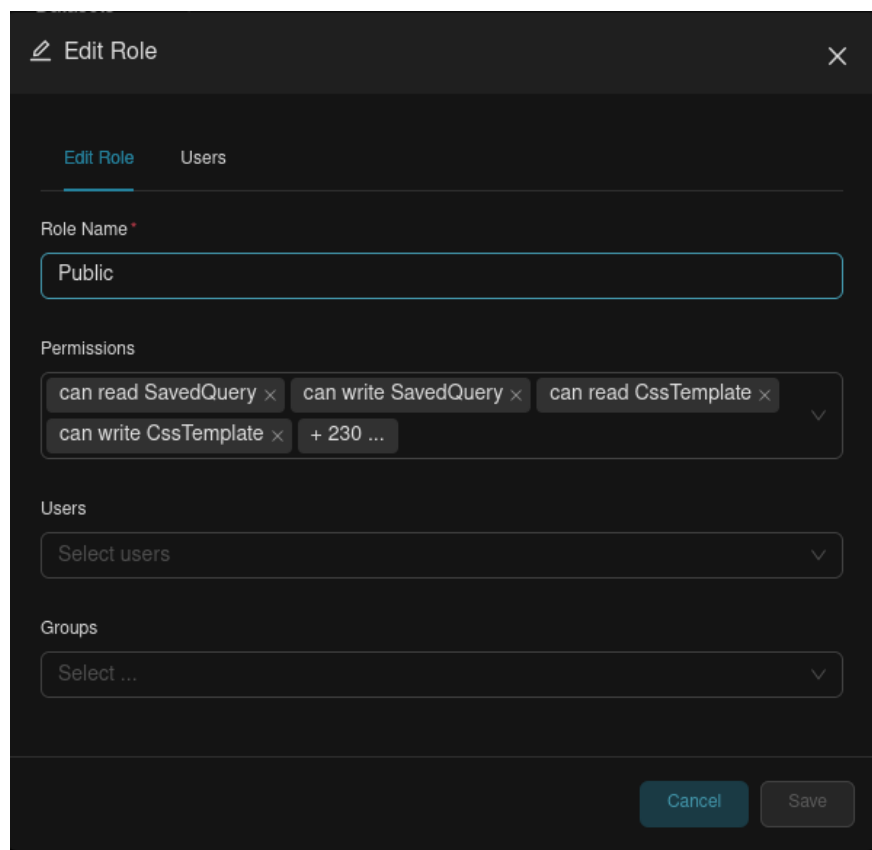


Figura 1
Configuración de permisos de base de datos para el rol Public en la interfaz de Superset.

3 Desarrollo del Backend: Autenticación en PHP

La aplicación web no debe exponer credenciales en el lado del cliente (frontend). Por ello, el servidor PHP actúa como intermediario seguro para generar un *Guest Token*.

3.1 Proceso de Obtención de Tokens

El flujo de autenticación consta de dos peticiones a la API REST de Superset:

1. **Autenticación Administrativa (/api/v1/security/login):** El script PHP envía las credenciales de administrador para obtener un *Access Token* temporal.
2. **Generación del Pase de Invitado (/api/v1/security/guest_token/):** Utilizando el *Access Token*, PHP solicita un *Guest Token*. En este paso se envía el UUID del *dashboard* a incrustar y se pueden inyectar reglas RLS (*Row Level Security*) para filtrar los datos mostrados según el usuario activo.

```
<?php
require_once __DIR__ . '/includes/auth.php';
require_login();

$uuid = $_GET['uuid'] ?? '';
if (!$uuid) {
    http_response_code(400);
    die("Falta_el_UUID_del_dashboard");
}

$superset_url = 'http://172.16.8.45:8088';
$superset_user = 'admin';
$superset_pass = '*****'; // <-- Credenciales abstraídas por
seguridad
```

```

// 1. Login
$ch = curl_init("$superset_url/api/v1/security/login");
curl_setopt($ch, CURLOPT_RETURNTRANSFER, true);
curl_setopt($ch, CURLOPT_HTTPHEADER, ['Content-Type:_application/json'
]);
curl_setopt($ch, CURLOPT_POST, true);
curl_setopt($ch, CURLOPT_POSTFIELDS, json_encode([
    'username' => $superset_user,
    'password' => $superset_pass,
    'provider' => 'db'
]));
$login_resp = json_decode(curl_exec($ch), true);
curl_close($ch);

$access_token = $login_resp['access_token'] ?? null;

// 2. Guest Token
$guest_payload = [
    'user' => [
        'username' => $_SESSION['username'],
        'first_name' => 'Usuario',
        'last_name' => 'Web'
    ],
    'resources' => [
        ['type' => 'dashboard', 'id' => $uuid]
    ],
    'rls' => []
];

```

```

$ch2 = curl_init("$superset_url/api/v1/security/guest_token/");
curl_setopt($ch2, CURLOPT_RETURNTRANSFER, true);
curl_setopt($ch2, CURLOPT_HTTPHEADER, [
    'Content-Type:_application/json',
    "Authorization:_Bearer_{$access_token}"
]);
curl_setopt($ch2, CURLOPT_POST, true);
curl_setopt($ch2, CURLOPT_POSTFIELDS, json_encode($guest_payload));
$guest_resp = json_decode(curl_exec($ch2), true);
curl_close($ch2);

// Imprime solo el token puro para que JavaScript lo consuma
echo $guest_resp['token'] ?? "";
?>

```

Listing 3: Script en PHP (get_token.php) para la comunicación con la API de Superset

4 Desarrollo del Frontend: Embedded SDK

Una vez que el backend es capaz de proveer el *Guest Token*, la capa de presentación (HTML/JavaScript) se encarga de renderizar el gráfico utilizando la librería oficial `@superset-ui/embedded-sdk`.

Se sustituye el uso de etiquetas `<iframe>` estáticas por un contenedor `<div>` vacío. El SDK invoca una función asíncrona que contacta al script PHP, recupera el token en texto plano, y construye dinámicamente el *dashboard* dentro del contenedor, aplicando las configuraciones visuales (como ocultar el título nativo del tablero).

```

<div id="superset-container" style="min-height:_700px;"></div>
<script src="https://unpkg.com/@superset-ui/embedded-sdk"></script>
<script>

```

```

supersetEmbeddedSdk.embedDashboard({
  id: "UUID-DEL-DASHBOARD",
  supersetDomain: "http://ip-del-servidor:8088",
  mountPoint: document.getElementById("superset-container"),
  fetchGuestToken: () => fetch("get_token.php").then(res => res.
    text())
});
</script>

```

Listing 4: Inyección del dashboard mediante JavaScript en la vista del cliente

5 Paso a Producción (Cloud / Servidor VPS)

La configuración expuesta en los apartados anteriores está optimizada para entornos de desarrollo local. Para migrar el sistema a un entorno de producción (servidor en la nube o VPS asociado a un dominio), se deben aplicar cambios estrictos para garantizar la seguridad perimetral.

5.1 Restricción de Orígenes y Dominios (CORS)

Se debe abandonar el uso del comodín universal (*). En el archivo `superset_config.py`, la variable `origins` debe contener explícitamente el dominio de la aplicación web:

```

CORS_OPTIONS = {
    'origins': ['https://www.midominio.com']
}

```

Asimismo, en la interfaz visual de Superset, al habilitar la incrustación (*Embed Dashboard*), el campo de *Allowed Domains* debe limitarse estrictamente a `midominio.com`.

5.2 Implementación de Certificados SSL/HTTPS

Los navegadores modernos bloquean la incrustación de contenido a través de *iframes* dinámicos si existe contenido mixto (*Mixed Content*). Es imperativo que tanto el servidor web PHP como

el servicio de Apache Superset cuentan con certificados SSL válidos y operen exclusivamente bajo el protocolo HTTPS.

5.3 Protección de Credenciales

Las credenciales de administrador de Superset y las direcciones IP expuestas en el código fuente de PHP deben ser abstraídas y trasladadas a variables de entorno protegidas o archivos de configuración cifrados (.env), asegurando que no queden registradas en sistemas de control de versiones.

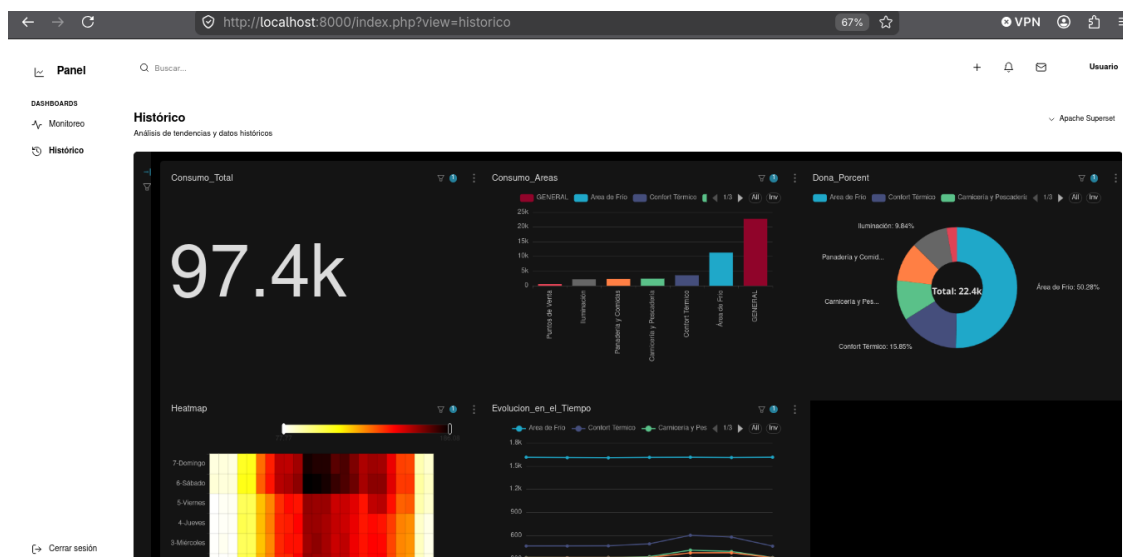


Figura 2
Visualización en producción del dashboard correctamente incrustado y validado.